DOCUMENTS

SINGLE SIGN-ON

Einrichtung und Installation

VERSION 3.1.7 / DOCUMENTS

© Copyright 2025 otris software AG. Alle Rechte vorbehalten.

Weitergabe und Vervielfältigung dieser Publikation oder von Teilen daraus sind, zu welchem Zweck und in welcher Form auch immer, ohne die ausdrückliche schriftliche Genehmigung durch die otris software AG nicht gestattet. In dieser Publikation enthaltene Informationen können ohne vorherige Ankündigung geändert werden.

Alle in dieser Publikation aufgeführten Wort- und Bildmarken sind Eigentum der entsprechenden Hersteller.

Änderungen in der Software sind vorbehalten. Die in diesem Handbuch enthaltenen Informationen stellen keinerlei Verpflichtung seitens des Verkäufers dar.

Dokumentenversionen			
Version	**Datum**	**Autor**	**Bemerkungen / Änderungen**
V 1.0	07.07.2016	Albuschat	Umstellung auf documents 5
V 2.0	21.04.2017	Urbschat	Aktualisierungen/Korrekturen
V 3.0	16.03.2018	Pajonzek	Grundlegende Überarbeitung des Handbuchs
V 3.0.1	07.02.2019	Pajonzek	Neue Waffle-Version berücksichtigt.
V 3.0.2	13.02.2019	Pajonzek	Troubleshooting für Waffle ergänzt
V 3.0.3	13.11.2019	Pajonzek	Die globale Eigenschaft hasAutologinLink
V 3.0.4	18.12.2019	Pajonzek	Verschlüsselungsalgorithmus auf Domänen – Clients erzwingen
V 3.0.5	22.01.2020	Pajonzek	Kapitel 3.2: Hinweis auf mögliche Verschlüsselungsalgorithmen seitens der Datei krb5.conf, Überarbeitung des Kapitels 2.5: Troubleshooting für Waffle
V 3.0.6	17.04.2020	Pajonzek	Anpassung Kap. 1.5 für den Edge (Chromium) Verweis auf die aktuelle Waffle – Version 2.2.1
V 3.0.7	02.03.2021	Pajonzek	Neue Waffle-Version 2.3.0,

			Anpassung der Kapitel 2.3.3 und 3.4.3, Anpassung des Kapitels 3.3
V 3.0.8	24.03.2021	Pajonzek	Kleine Korrekturen an Kapitel 3.1.3 Ergänzung im Kapitel 3.6.3: Befehl “klist purge”
V 3.0.9	06.05.2021	Pajonzek	Korrekturen / Ergänzungen Kap.: 3.2, 3.6.3, 1.2.3
V 3.1.0	20.06.2022	Pajonzek	Ergänzung des Kapitels 3.6.2: Fehlermeldungen und Maßnahmen beim Troubleshooting SPNEGO mit Kerberos, Überarbeitung von Kapitel 4: Sicherstellen eine funktionsfähigen SSO - Umgebung
V 3.1.1	30.11.2022	Pajonzek	Neue Waffle – Version 3.2.0
V 3.1.2	15.12.2022	Pajonzek	Ergänzung in Kapitel 3.6.2
V 3.1.3	24.04.2023	Pajonzek	Neue Kapitel 2.3.3 und 3.4.3: Änderungen im SSO – Filter bei Documents 6
V 3.1.4	23.10.2023	Pajonzek	Neue Waffle – Version 3.3.0, Anpassungen des Handbuchtextes, der URLs und Verzeichnispfade auf Documents 6
V 3.1.5	29.07.2024	Pajonzek	Neue Waffle – Version 3.4.0
V 3.1.6	25.10.2024	Pajonzek	Neue Waffle – Version 3.5.0
V 3.1.7	01.07.2025	Pajonzek	Neue Waffle – Version 3.5.1

Inhaltsverzeichnis

1. Allgemein 6

1.1 Nutzen von Single Sign-On 6
1.2 Voraussetzungen 6
1.2.1 Domänencontroller 6
1.2.2 Applikationsserver 6
1.2.3 Arbeitsplatz 6
1.2.4 Authentifizierungsmethode 7
1.3 Einrichtung des DOCUMENTS Servers 7
1.4 Einstellungen in den „Eigenschaften von Internet“ unter Windows 8
1.4.1 Aktivierung des automatischen Logins 8
1.4.2 Integrierte Windows-Authentifizierung aktivieren 10
1.5 Hinzufügen des Servernamens zu den vertrauenswürdigen Sites 11
1.6 Auswahl des Authentifizierungsmoduls 12
1.7 Übersicht über die Systemumgebung 13
1.8 Die globale Eigenschaft *hasAutologinLink* 13

2. SSO mit WAFFLE (NTLMv2) 15

2.1 Installation von Waffle 15
2.2 Hinweis zur Verwendung des Authentifizierungsmoduls NTLMv2 unter Waffle 15
2.3 Einträge in der web.xml 15
2.3.1 Einträge im Waffle-Filter bei NTLM Authentifizierung 16
2.3.2 Einträge im SSO Filter bei NTLM Authentifizierung (Documents 5) 17
2.3.3 Einträge im SSO Filter bei NTLM Authentifizierung (Documents 6) 17
2.3.4 Modifizierungen bei allen anderen Filtern 17
2.4 Einrichtung von Firefox 18
2.5 Troubleshooting für Waffle 18

3. SSO mit SPNEGO (Kerberos) 20

3.1 Einrichtung des Active Directory 20
3.1.1 Verschlüsselungsalgorithmus auf Domänen – Clients erzwingen 20
3.1.2 Anlegen des benötigten Benutzerkontos 22
3.1.3 Einrichten der Service Principal Names (SPN) 23
3.2 Konfigurationsdateien für SPNEGO 25
3.3 Installation von SPNEGO 26
3.4 Einträge in der web.xml 26
3.4.1 Einträge im SPNEGO-Filter 27
3.4.2 Einträge im SSO-Filter (Documents 5) 28
3.4.3 Einträge im SSO Filter (Documents 6) 29
3.4.4 Modifizierungen bei allen anderen Filtern 29
3.5 Einrichtung von Firefox 30
3.6 Troubleshooting SPNEGO mit Kerberos 30
3.6.1 Häufige Fehlerquellen: 30

3.6.2 Fehlermeldungen und Maßnahmen 31
3.6.3 HelloKDC – Config-Test..... 32
3.6.4 Hilfsmittel Befehlszeilenwerkzeug *„klist“* 34

4. Häufige Fehler 37

5. Abbildungsverzeichnis 39

1. Allgemein

1.1 Nutzen von Single Sign-On

Durch die Verwendung von Single Sign-On (SSO) muss sich ein Benutzer nur einmal an einem Arbeitsplatz authentifizieren und kann dann auf alle Ressourcen und Dienste zugreifen, für die er eine Berechtigung hat. Eine erneute Anmeldung ist nicht erforderlich. DOCUMENTS unterstützt im Hinblick auf SSO mehrere Standardverfahren zur Authentifizierung. Die Einrichtung der Systemlandschaft zur Nutzung dieser Authentifizierungsverfahren mit DOCUMENTS ist in diesem Dokument beschrieben.

1.2 Voraussetzungen

Um SSO einsetzen zu können, müssen folgende Voraussetzungen für die Systemlandschaft gegeben sein:

1.2.1 Domänencontroller

Es muss eine Domäne existieren, die von einem Domänencontroller verwaltet wird, der ein *Active Directory* bereitstellt. Voraussetzung ist das Betriebssystem *Microsoft Windows Server* (getestet mit Version 2008, 2012 (R2), 2016).

1.2.2 Applikationsserver

Der Applikationsserver, auf dem die **DOCUMENTS**-Installation läuft, muss vom Domänencontroller und von den Arbeitsplätzen des Netzwerks erreichbar sein. Der Server ist auch Mitglied in der Domäne.

1.2.3 Arbeitsplatz

Jeder Arbeitsplatz-Rechner, von dem aus SSO nutzbar sein soll, muss Mitglied der Domäne sein. Ebenso muss jeder Benutzer, der sich per SSO anmelden soll, Mitglied in der Domäne sein und unter dem gleichen Benutzernamen im **DOCUMENTS** – oder bei vorhandener LDAP-Kopplung – im LDAP angelegt sein. Das Passwort des Benutzers muss in der Domäne und im **DOCUMENTS** bzw. LDAP identisch sein.

Wird von einem Arbeitsplatz zugegriffen, der nicht Mitglied der Domäne ist, so wird ein Standarddialog des Browsers (Basic-Auth) verwendet, um Benutzername und Passwort vom Benutzer abzufragen (vgl. Abb. 1). Der Benutzer wird dann gegen die Domäne authentifiziert und erhält Zugang zu **DOCUMENTS**.

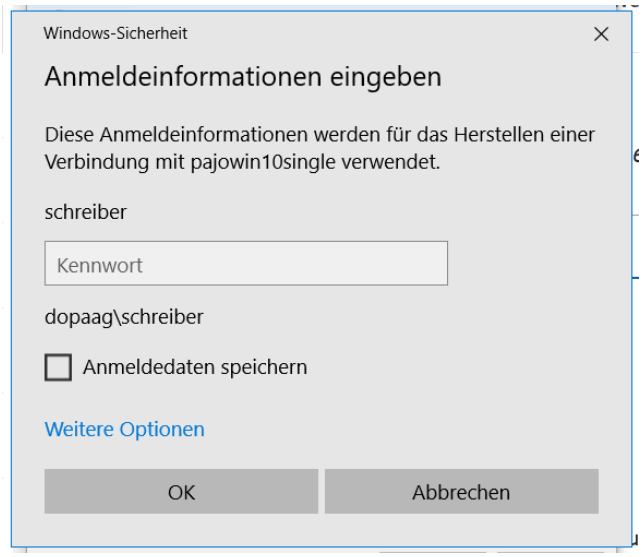

Abb. 1: Standard-Anmeldedialog unter Windows 10 an der Domäne „dopaag“ mit dem Benutzer „schreiber“

Da auf dem Arbeitsplatz der Webbrowser zur Verwendung von SSO eingesetzt werden soll, ist ein Clientbetriebssystem empfehlenswert, da auf Serverbetriebssystemen erweiterte Sicherheitseinstellungen für die Verwendung von Webbrowsern bestehen.[1]

1.2.4 Authentifizierungsmethode

Für die Einrichtung von SSO ist es nötig, die zu verwendende Authentifizierungsmethode zu kennen. Es werden *NTLMv1*[2], *NTLMv2* und *Kerberos* unterstützt. Welche Authentifizierungsmethode verwendet werden soll, muss vom Systemadministrator festgelegt werden.

1.3 Einrichtung des DOCUMENTS Servers

Es muss zum Betrieb von SSO sichergestellt sein, dass unter Documents -> Einstellungen ein Haken bei *Automatisches Login* gesetzt ist. Dabei muss die Gültigkeitsdauer auf *„0“* gesetzt sein. Bei einem Wert > 0 ist SSO nicht aktiv. Es wird eine automatische Neuanmeldung innerhalb des hier angegebenen Zeitraums nach dem Ablauf der Benutzersitzung bei Benutzeraktivität erfolgen.

---

[1] Vgl. hierzu: https://docs.microsoft.com/de-de/troubleshoot/browsers/enhanced-security-configuration-faq
[2] NTLMv1 wird nur bis Windows Server 2003 unterstützt (vgl.: https://support.microsoft.com/de-de/help/2793313/security-guidance-for-ntlmv1-and-lm-network-authentication)

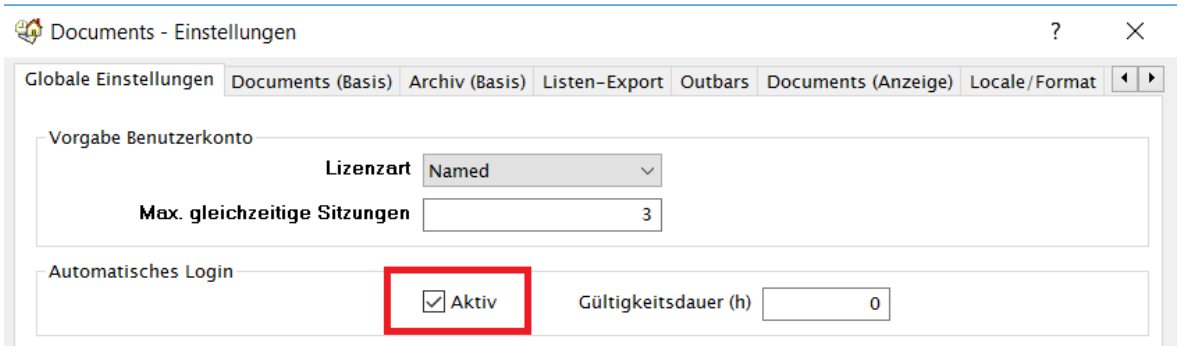

Abb. 2: Automatisches Login

1.4 Einstellungen in den „Eigenschaften von Internet“ unter Windows

Um SSO unter Windows auf einem Clientrechner nutzen zu können, müssen die im Folgenden beschriebenen Einstellungen aktiviert sein. **Diese sind auf einem Clientbetriebssystem wie Windows 10 nach einer Neuinstallation bereits aktiv.** Die „Internetoptionen“ (Aufruf aus dem Internet Explorer) bzw. „Eigenschaften von Internet“ sind auch ausgehend von verschiedenen Browsern erreichbar. Im Folgenden soll jedoch der Weg über die Systemsteuerung beschrieben werden. Aufgerufen aus der Systemsteuerung heißen die „Internetoptionen“ „Eigenschaften von Internet“.

1.4.1 Aktivierung des automatischen Logins

Um den automatischen Login in der Intranet-Zone zu erlauben, muss folgende Option aus Abb 3 und Abb. 4 aktiviert werden:

Systemsteuerung -> Netzwerk und Internet -> Internetoptionen -> Sicherheit -> Lokales Intranet -> Stufe Anpassen -> Benutzer Authentifizierung -> Anmeldung -> „Automatisches Anmelden nur in der Intranetzone“

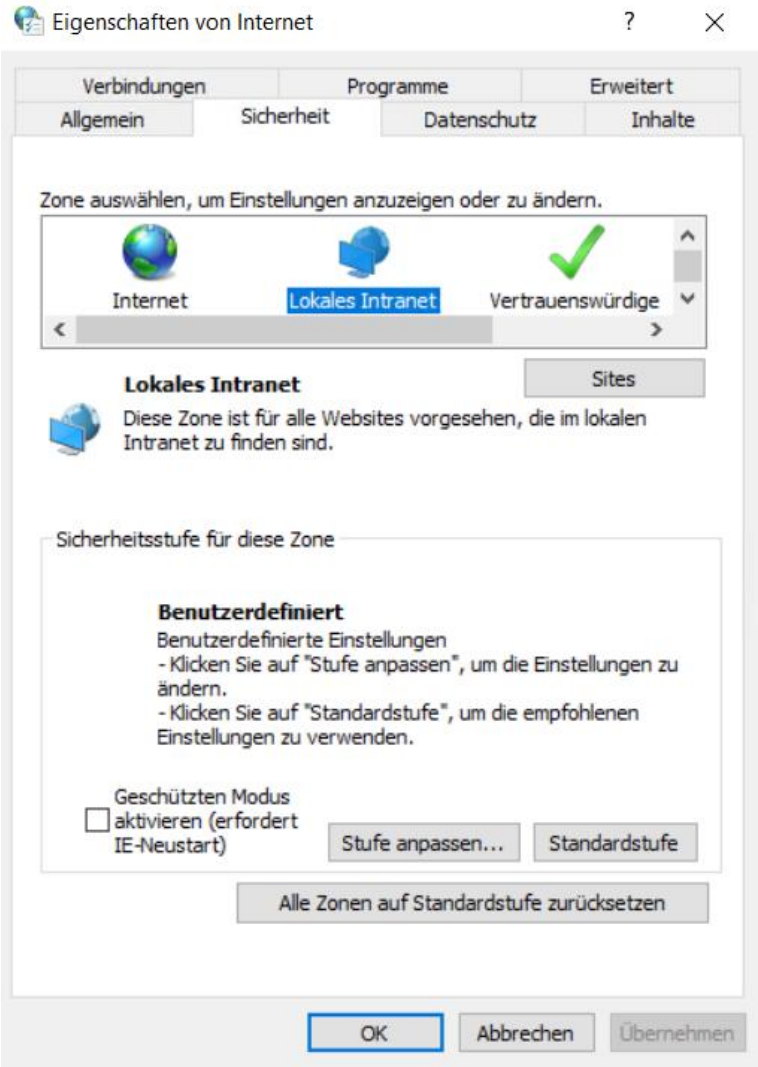

Abb. 3: Dialog "Eigenschaften von Internet"

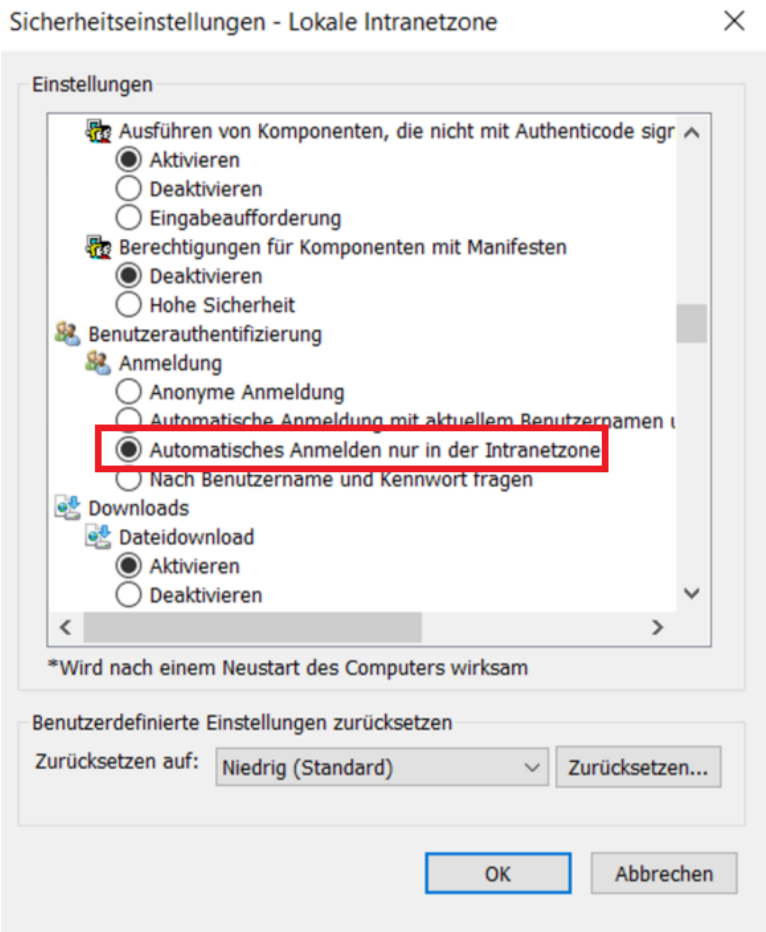

Abb. 4: Automatisches Anmelden nur in der Intranetzone aktiviert

1.4.2 Integrierte Windows-Authentifizierung aktivieren

Die Aktivierung dieser Option erfolgt im Reiter „*Erweitert*“ des Dialogs „Eigenschaften von Internet“. Hier muss die Option „*Integrierte Windows-Authentifizierung aktivieren*“ ausgewählt sein (vgl. Abb. 5). Die mit „*“ gekennzeichneten Optionen werden erst nach einem Neustart des Computers wirksam.

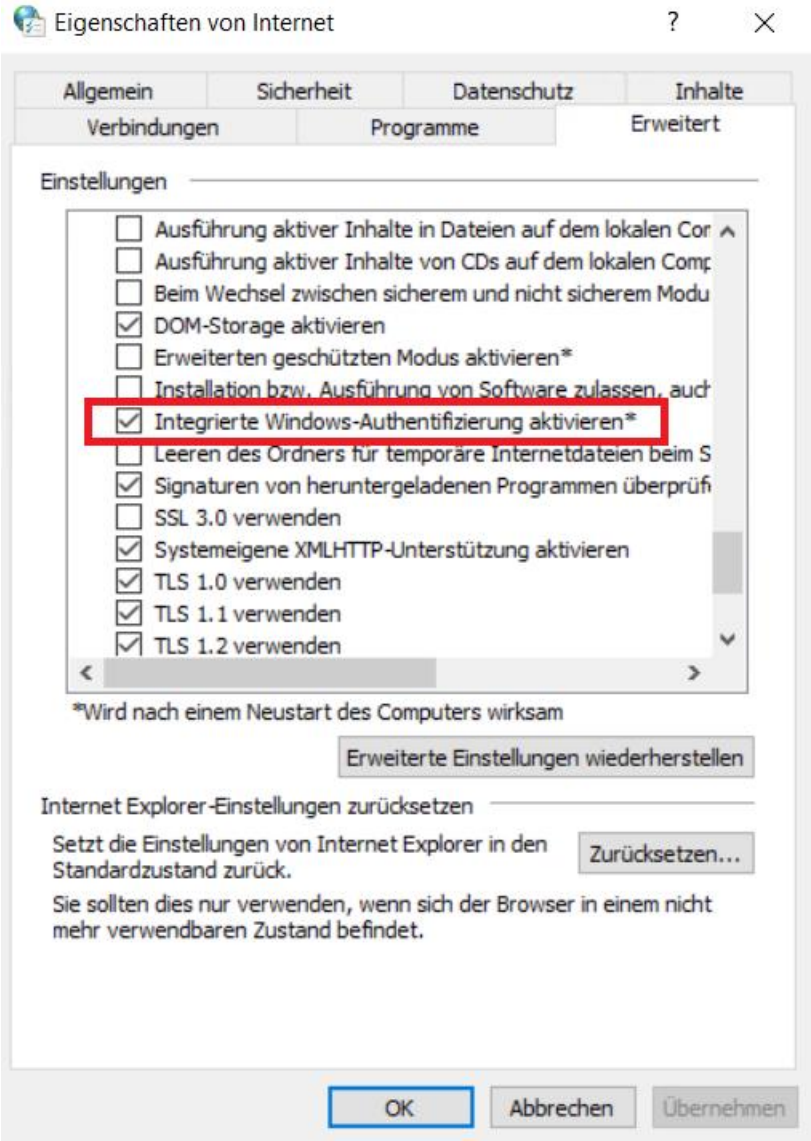

Abb. 5: Integrierte Windows-Authentifizierung aktivieren

1.5 Hinzufügen des Servernamens zu den vertrauenswürdigen Sites

Für ein funktionsfähiges SSO muss der Rechnername der Documents - Serverinstallation in die Liste „Lokales Intranet“ aufgenommen werden (Abb. 6). Alternativ kann der Servername auch in die Liste der „vertrauenswürdigen Sites“ eingetragen werden. Im Browser Chrome und im Edge auf der Basis von Chromium (Programmversion 81 und höher, erschienen im Januar 2020) ist SSO nur über einen Eintrag in die Liste „Lokales Intranet“ möglich.

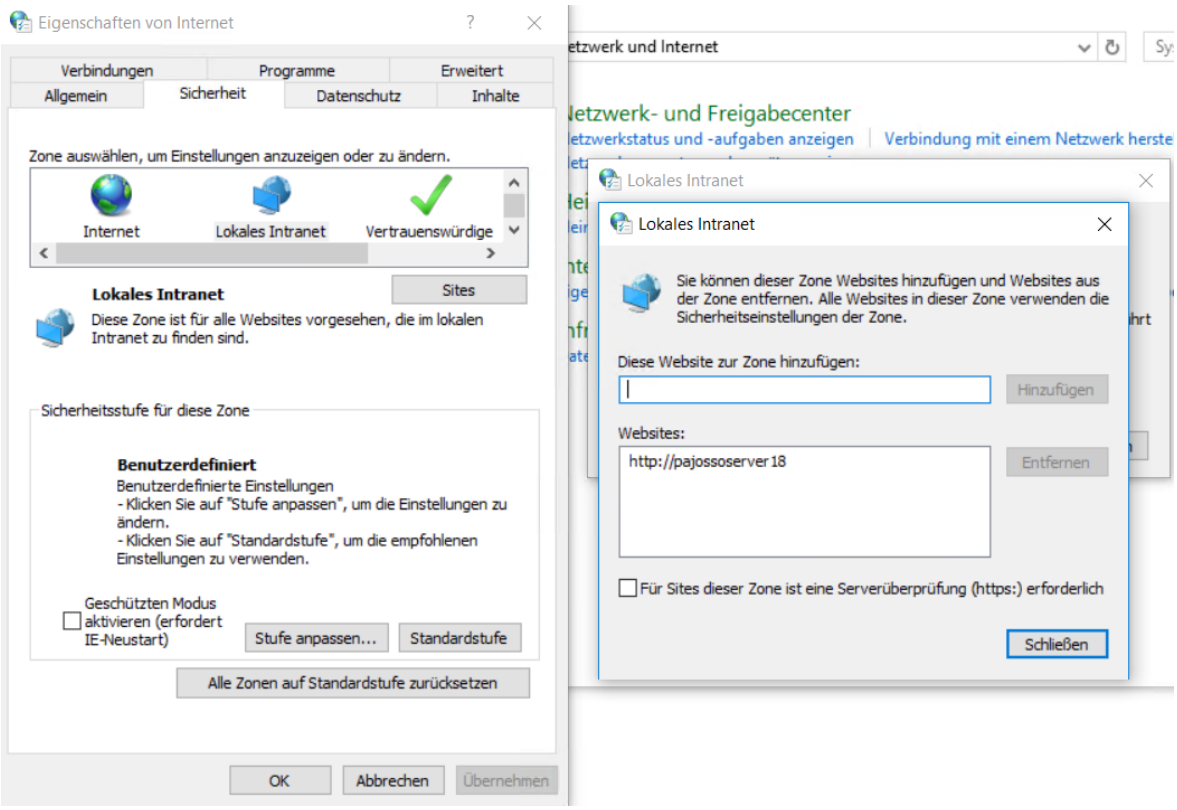

Abb. 6: Aufnahme des Servernamens in die Liste „Lokales Intranet“

1.6 Auswahl des Authentifizierungsmoduls

Zur Durchführung der Authentifizierung am Active-Directory stehen mehrere Authentifizierungsmodule zur Verfügung. Die Auswahl des Moduls hängt davon ab, welche Methode zur Authentifizierung verwendet werden soll.

Anhand der folgenden Tabelle kann mithilfe der Authentifizierungsmethode das passende Authentifizierungsmodul ausgewählt werden.

Auth.-Modul / Auth.-Methode	**NTLMv1**[3]	**NTLMv2**	**Kerberos**
WAFFLE*	Ja	Ja	Nein
SPNEGO	Nein	Nein[4]	Ja

* Für Waffle muss der Anwendungsserver / Tomcat auf einem Windows System laufen.

[3] Wird nur bis Windows Server 2003 unterstützt (vgl.: https://support.microsoft.com/de-de/help/2793313/security-guidance-for-ntlmv1-and-lm-network-authentication)
[4] Dieses Authentifizierungsverfahren wird nicht unterstützt. Dieses Handbuch erläutert einen Authentifizierungsmechanismus für SPNEGO auf der Basis von Kerberos

1.7 Übersicht über die Systemumgebung

Abb. 7 zeigt den Aufbau der Systemumgebung für die Nutzung von SSO mit **DOCUMENTS**:

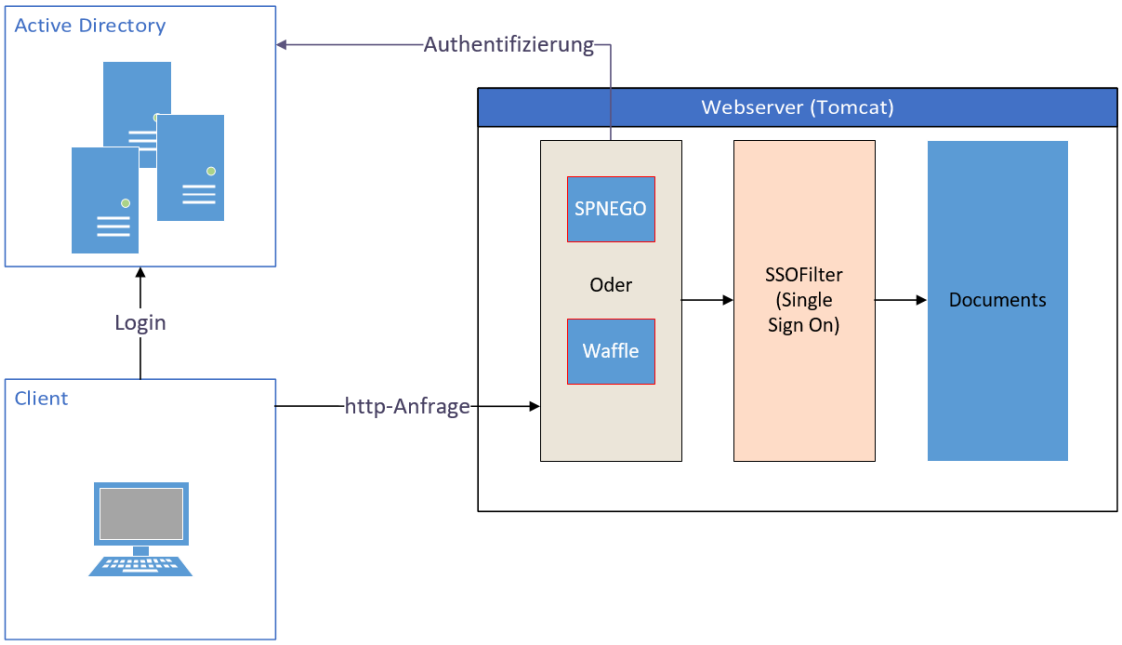

Abb. 7: Systemumgebung für die Nutzung von SSO

In den folgenden Abschnitten wird beschrieben, welche Schritte für die Einrichtung der verschiedenen Authentifizierungsmodule durchgeführt werden müssen.

1.8 Die globale Eigenschaft *hasAutologinLink*

Wenn diese Eigenschaft global gesetzt ist, wird ein Link für die automatische SSO – Anmeldung auf der Loginseite angezeigt. Wenn dieser angeclickt wird, wird eine SSO – Anmeldung ausgeführt. Folgende Werte für die Eigenschaft sind möglich:

Mögliche Werte	Auswirkung
true, 1 (ausschalten mit false bzw. 0, der Standardwert ist false bzw. 0)	Es wird auf der Loginseite ein Link “Automatische Anmeldung” bzw. “automatic login”, je nach Sprachauswahl angezeigt.
de:Mein Link;en:My link	Wenn man ein eigenes Label definiert, wird implizit "hasAutologinLink = true" angenommen. - Die

	unterschiedlichen Labeldefinitionen werden, je nach Sprach-auswahl, angezeigt.

Abb. 8: Standardlink für die automatische Anmeldung bei hasAutologinLink = true

2. SSO mit WAFFLE (NTLMv2)

Bitte beachten Sie, dass die Voraussetzung für die Arbeitsschritte in Kapitel 2 die vollständige Bearbeitung von Kapitel 1 ist. Hier werden Themen wie Rechnerinfrastruktur, Benutzer und Windows-Konfiguration behandelt. Diese sind zwingend erforderlich dafür, dass eine Einrichtung von SSO mit Waffle gelingt.

2.1 Installation von Waffle

Zunächst muss das Waffle Paket von **https://github.com/Waffle/waffle** → **Essentials** → **Download Version 3.5.1** heruntergeladen werden. In dem heruntergeladenen Archiv mit dem Namen `waffle-distro-3.5.1-distro.zip` befindet sich das Verzeichnis `\Bin`. Alle Dateien darin müssen in das Verzeichnis `C:\Program Files\Documents<5/6>\tomcat<8/9>)\webapps\documents\WEB-INF\lib` kopiert werden. Nach Abschluss aller im Folgenden beschriebenen Arbeiten ist ein Neustart des Tomcat erforderlich. Waffle wurde in der Version 3.5.1 erfolgreich getestet. Die Versionshistorie von Waffle können Sie unter **https://github.com/Waffle/waffle/releases** einsehen.

2.2 Hinweis zur Verwendung des Authentifizierungsmoduls NTLMv2 unter Waffle[5]

Waffle erlaubt die Authentifizierung sowohl mit NTLMv1 als auch mit NTLMv2. Wenn sichergestellt werden soll, dass NTLMv2 verwendet wird, muss dies in den Gruppenrichtlinien des Domänencontrollers eingestellt werden.
Die Einstellung ist am Domänencontroller zu finden unter: → Server Manager → Tools → Gruppenrichtlinienverwaltung → Default Domain Controllers Policy → Rechtsclick: bearbeiten → Computerkonfiguration → Richtlinien → Windows-Einstellungen → Sicherheitseinstellungen → Lokale Richtlinien → Sicherheitsoptionen und heißt „Netzwerksicherheit: LANManager-Authentifizierungsebene“. Hier ist die jeweils zutreffende Option zu wählen.

2.3 Einträge in der web.xml

Zur Nutzung von SSO mit Waffle müssen in der Datei `web.xml` einige Einträge vorgenommen werden. Ab Documents 5.0 c HF 1 werden diese Einträge in der web.xml

[5] Ab Windows Server 2014 müssen diese Einstellungen nicht mehr getroffen werden (vgl.: https://msdn.microsoft.com/de-de/library/jj852207(d=printer,v=ws.11).aspx)

mit ausgeliefert. Sie müssen lediglich einkommentiert werden. Die Datei befindet sich hier:

C:\Program Files\Documents<5/6>\tomcat<8/9>\webapps\documents\WEB-INF

Die hier dargestellten URLs ermöglichen jeweils eine sofortige Anmeldung per Autologin und QuickView – Link. Bei einem Session – Timeout erfolgt keine Reauthentifizierung und keine erneute, automatische Anmeldung. Man wird zum Anmeldeformular zurückgeleitet. Die hier angegebenen Verzeichnisse werden jeweils durch eine SSO – Authentifizierung gesichert. Bitte beachten Sie, dass * - Verweise und Verweise auf einzelne Dateien in einem Verzeichnis zu einer erhöhten Zahl der Authentifizierungsvorgänge führen können. Bitte beachten Sie, dass der Waffle-Filter vor dem SSO- Filter stehen muss.

Zur Anmeldung mittels Autologin orientieren Sie sich bitte an der folgenden URL, da sie zu der unten stehenden Konfiguration passt („dopaag“ ist im vorliegenden Beispiel der Mandantenname):

http://servername:8080/documents/autologin/login?pri=dopaag

Das folgende Beispiel stellt einen Quick-View-Link auf ein EEX – Archiv dar:

http://servername:8080/documents/jsp/qv?pri=9999&vw=Media&q_Beschreibung=Thema → „*9999*“ ist der Mandantenname, „*Media*“ der Name einer View und „*Beschreibung*“ der Name eines Feldes der Archivmappe.

2.3.1 Einträge im Waffle-Filter bei NTLM Authentifizierung

```
<!— Dieser Filter ist in der Standard web.xml schon vorhanden (auskommentiert) -->

<filter>
        <filter-name>WaffleFilter</filter-name>
        <filter-class>waffle.servlet.NegotiateSecurityFilter</filter-class>
        <init-param>
        <param-name>waffle.servlet.spi.NegotiateSecurityFilterProvider/protocols</param-name>
        <param-value>NTLM</param-value>
        </init-param>
</filter>

<filter-mapping>
          <filter-name>WaffleFilter</filter-name>
          <url-pattern>/autologin/login</url-pattern>
          <url-pattern>/jsp/qv</url-pattern>
</filter-mapping>
```

2.3.2 Einträge im SSO Filter bei NTLM Authentifizierung (Documents 5)

```
<!— Dieser Filter ist in der Standard web.xml schon vorhanden (auskommentiert) -->
<filter>
	<filter-name>SSOFilter</filter-name>
	<filter-class>de.otris.documents.web.filter.SSOFilter</filter-class>
</filter>

<filter-mapping>
	<filter-name>SSOFilter</filter-name>
	<url-pattern>/autologin/login</url-pattern>
	<url-pattern>/jsp/qv</url-pattern>
</filter-mapping>
```

2.3.3 Einträge im SSO Filter bei NTLM Authentifizierung (Documents 6)

Der folgende SSOFilter ist ab Documents 6 standardmäßig schon aktiv. Im Fall, dass der *PropertyMode* den Wert *„true“* hat und somit aktiv ist, funktioniert SSO nur wenn die globale Eigenschaft (Property) *ssoLoginMethod = sso* gesetzt ist. Wenn diese Eigenschaft nicht gesetzt ist, würde SSO nicht funktionieren. Bei nicht gesetzter Eigenschaft *ssoLoginMethod*, würde SSO nur funktionieren, wenn der *PropertyMode* aus ist und somit den Wert *„false“* hat.

```
<!— Dieser Filter ist in der Standard web.xml schon vorhanden (einkommentiert und aktiv) -->
	<filter>
		<filter-name>SSOFilter</filter-name>
		<filter-class>de.otris.documents.web.filter.SSOFilter</filter-class>
		<init-param>
			<param-name>PropertyMode</param-name>
			<param-value>true</param-value>
		</init-param>
	</filter>

	<filter-mapping>
		<filter-name>SSOFilter</filter-name>
		<url-pattern>/autologin/login</url-pattern>
		<url-pattern>/jsp/qv</url-pattern>
	</filter-mapping>
```

2.3.4 Modifizierungen bei allen anderen Filtern

Bitte beachten Sie, dass **bei allen anderen Filtern** das url-pattern für den Autologin (markierter Bereich) wie folgt aussehen muss (Bsp.: hier: Session Setup Filter). Ab Documents 5.0 c HF 1 werden diese Einträge in der web.xml mit ausgeliefert. Es muss also seitens der Benutzer keine Änderung mehr vorgenommen werden.

```
<filter-name>SessionSetupFilter</filter-name>
<url-pattern>*.act</url-pattern>
<url-pattern>*.jsp</url-pattern>
<url-pattern>/autologin/login</url-pattern>
```

Abb. 9: Modifikationen bei allen Filtern

2.4 Einrichtung von Firefox

Im Firefox öffnet sich bei Eingabe einer SSO- Anmelde- Url ein Fenster, in dem die Authentifizierungsdaten für SSO des Benutzers eingetragen werden müssen. Um dieses Problem zu umgehen, müssen modifizierte Einträge in den Konfigurationsparametern vorgenommen werden. Im Firefox können Sie die Konfigurationsparameter öffnen, indem Sie in der Browserzeile: *about:config* eingeben.

Dann müssen folgende Parameter gesetzt werden:

Einstellung	**Wert**
network.negotiate-auth.delegation-uris	Servername
network.automatic-ntlm-auth.trusted-uris	Servername
network.automatic-ntlm-auth.allow-proxies	True
network.negotiate-auth.allow-proxies	True

2.5 Troubleshooting für Waffle

Beim Verwenden des Tomcat als Dienst und nach dem Einspielen der Waffle – Paketdateien (vgl. 2.1), auch ohne die Nutzung von SSO, kann es sein, dass bei jedem Start des Dienstes die Log-Datei mit dem Namensanteil „stdout“ signifikant anwächst. Die Datei liegt in dem folgenden Verzeichnis einer Standardinstallation:
C:\Program Files\Documents<5/6>\logs\tomcat

Lokaler Datenträger (C:) > Programme > Documents5 > logs > tomcat

Name	Änderungsdatum	Typ	Größe
catalina.2019-02-13.log	13.02.2019 15:11	Textdokument	73 KB
commons-daemon.2019-02-13.log	13.02.2019 10:01	Textdokument	1 KB
documents_access_log..2019-02-13.txt	13.02.2019 15:10	Textdokument	766 KB
documents5tomcat8-stderr.2019-02-13.l...	13.02.2019 10:01	Textdokument	0 KB
documents5tomcat8-stdout.2019-02-13.l...	13.02.2019 10:01	Textdokument	0 KB
DoNotDelete	07.06.2018 15:03	Datei	0 KB
host-manager.2019-02-13.log	13.02.2019 10:19	Textdokument	0 KB
localhost.2019-02-13.log	13.02.2019 10:19	Textdokument	0 KB
manager.2019-02-13.log	13.02.2019 10:19	Textdokument	0 KB

Abb. 10: Logdatei mit dem Namensanteil „stdout“

Ein Anwachsen der Datei kann man durch Konfiguration der Datei „logback.xml“ verhindern. Hierzu stellt man in der Datei den Loglevel auf „error“. Nach dieser Änderung wächst die Logdatei nicht mehr nach jedem Start des Tomcat – Dienstes an.
Die Datei „logback.xml“ muss eigenständig erstellt werden und dann in folgendem Verzeichnis einer Standardinstallation liegen:
C:\Program Files\Documents<5/6>\tomcat<8/9>\webapps\documents\WEB-INF\classes
Mit der Datei „logback.xml“ wird der Umfang der Logausgaben in der Logdatei mit dem Namensanteil „stdout“ bei erneutem Start des Tomcat – Dienstes gesteuert. Die Ausgaben sind bei <root level="error"> beispielsweise geringer als bei <root level="debug">

```
<?xml version="1.0" encoding="UTF-8"?>


<configuration>


<appender name="STDOUT" class="ch.qos.logback.core.ConsoleAppender">
        <!-- encoders are assigned the type
        ch.qos.logback.classic.encoder.PatternLayoutEncoder by default -->
        <encoder>
          <pattern>%d{HH:mm:ss.SSS} [%thread] %-5level %logger{36} - %msg%n</pattern>
        </encoder>
</appender>


<root level="error">
        <appender-ref ref="STDOUT" />
</root>
</configuration>
```

Abb. 11: Beispiel für den Aufbau der Datei „logback.xml“

3. SSO mit SPNEGO (Kerberos)

Bitte beachten Sie, dass die Voraussetzung für die Arbeitsschritte in Kapitel 3 die vollständige Bearbeitung von Kapitel 1 ist. Hier werden Themen wie Rechnerinfrastruktur, Benutzer und Windows-Konfiguration behandelt. Diese sind zwingend erforderlich dafür, dass eine Einrichtung von SSO mit SPNEGO gelingt.

3.1 Einrichtung des Active Directory

Um die Kerberos Authentifizierung zu nutzen, müssen einige Einstellungen am Domänen-Controller vorgenommen werden.

3.1.1 Verschlüsselungsalgorithmus auf Domänen – Clients erzwingen

Wir zeigen beispielhaft die Einrichtung einer Verschlüsselung mit dem Verschlüsselungstyp AES 256 (AES256_HMAC_SHA1). Diese Einstellung erzwingt eine ganz bestimmte Konfiguration der Datei krb5.conf (vgl. Kap.: 3.2). Es ist möglich, dass Sie andere Verschlüsselungsalgorithmen konfigurieren. In der folgenden Konfiguration werden DES – Verschlüsselungsalgorithmen explizit deaktiviert, da stärkere kryptografische Verfahren verfügbar sind.[6] Bitte stellen Sie die Verschlüsselungsverfahren an der folgenden Stelle ein:

- Server Manager → Tools → lokale Sicherheitsrichtlinie → Sicherheitseinstellungen → lokale Richtlinien → Sicherheitsoptionen → Netzwerksicherheit: Für Kerberos zulässige Verschlüsselungstypen konfigurieren

Mit dieser Richtlinieneinstellung können Sie die Verschlüsselungstypen festlegen, die vom Kerberos-Client verwendet werden dürfen. Wenn diese Option nicht aktiviert ist, wird der Verschlüsselungstyp nicht zugelassen. Diese Einstellung wirkt sich möglicherweise auf die Kompatiblität mit Clientcomputern oder Diensten und Anwendungen aus.
Mehrfachauswahl ist zulässig.[7]

---

[6] https://docs.microsoft.com/de-de/windows/security/threat-protection/security-policy-settings/network-security-configure-encryption-types-allowed-for-kerberos
[7] https://docs.microsoft.com/de-de/windows/security/threat-protection/security-policy-settings/network-security-configure-encryption-types-allowed-for-kerberos

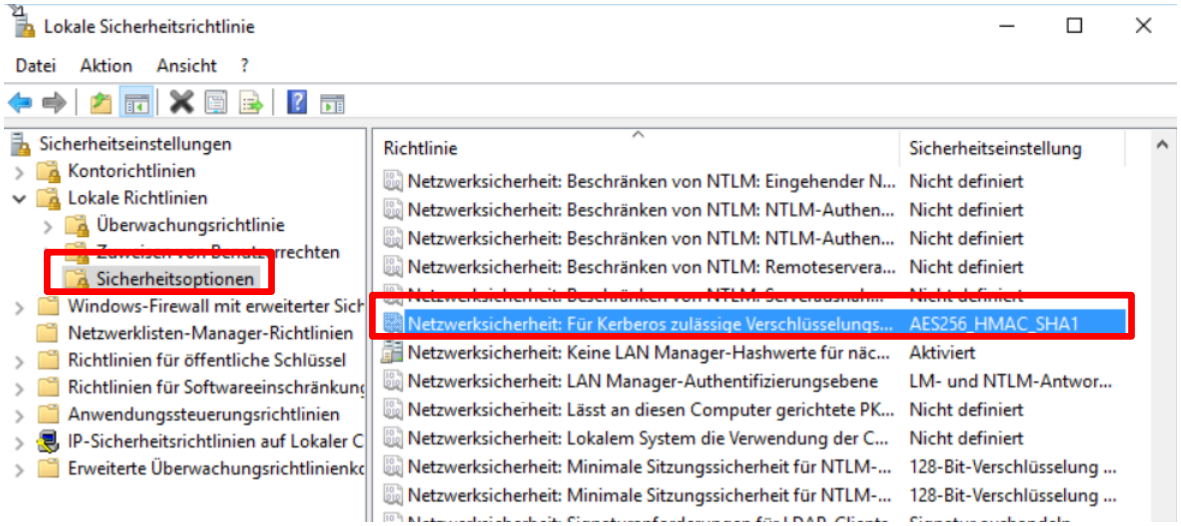

Abb. 12: für Kerberos zulässige Verschlüsselungstypen konfigurieren (Windows Server 2016)

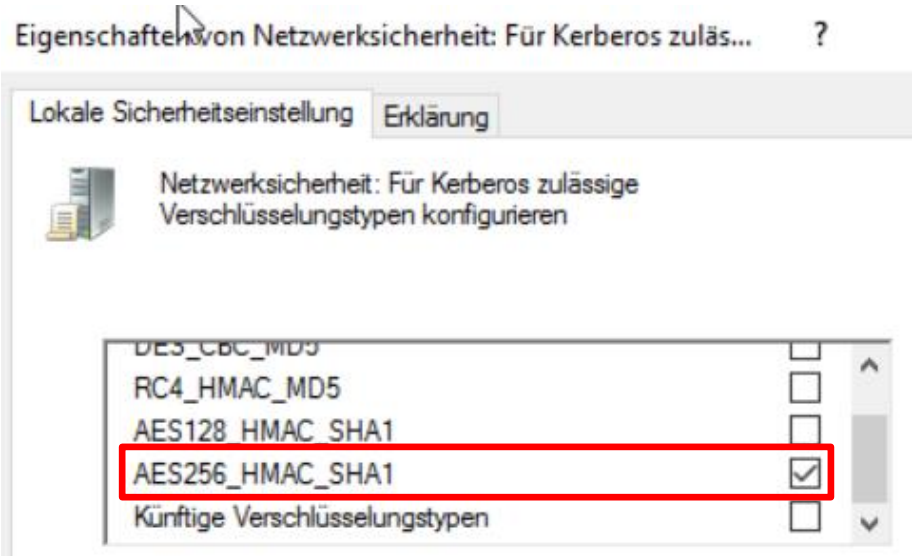

Abb. 13: Auswahl der zulässigen Verschlüsselungsverfahren (Windows Server 2016)

Darüber hinaus ist es möglich, am Benutzer (SPN) (zur Einrichtung siehe Kapitel 3.1.2 und 3.1.3) bestimmte Verschlüsselungsverfahren zu erzwingen. Dies ermöglicht, zusätzlich zu den oben genannten Konfigurationsmöglichkeiten, die Authentifizierung eines Benutzers auf ein bestimmtes Verfahren zu beschränken. Dies sehen wir jedoch eher als mögliche Fehlerquelle und raten daher davon ab. Somit sollte hier keine Verschlüsselung ausgewählt sein. Es besteht nämlich die Möglichkeit, dass Kerberos – Tickets für andere Verschlüsselungsverfahren als die hier ausgewählten existieren (vgl. Kap. 3.6.4). Mit einer Einschränkung würde jetzt die Anmeldung per SSO für diesen Benutzer oder über diesen SPN nicht mehr funktionieren. Zur Fehlervermeidung sollte man die Komplexität der Konfiguration hier möglichst gering halten.

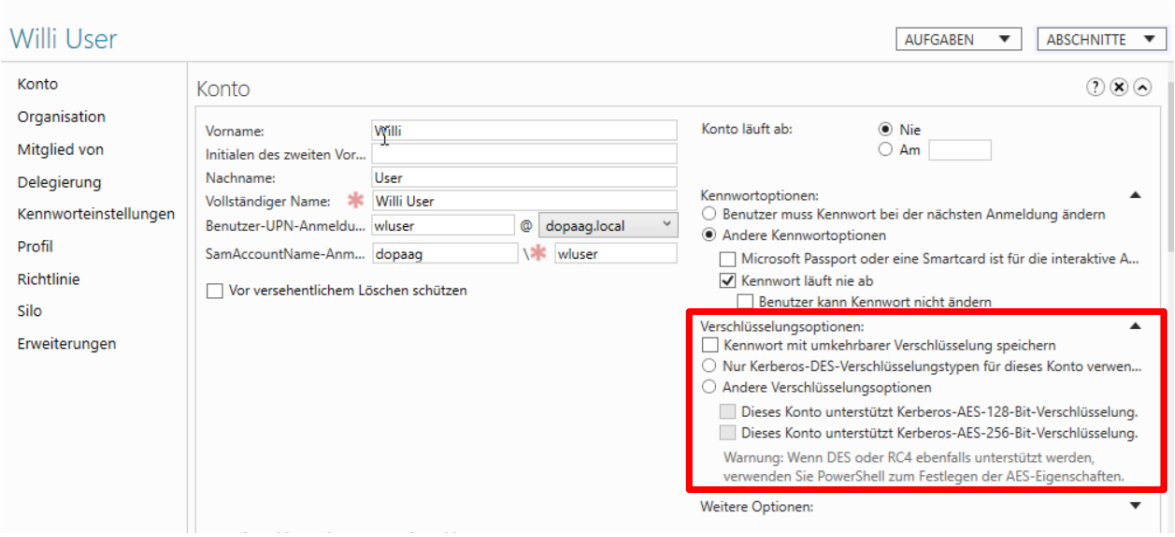

Abb. 14: Einstellungen am SPN „wluser“ im Active Directory Verwaltungscenter (Windows Server 2016)

3.1.2 Anlegen des benötigten Benutzerkontos

Die Authentifizierung mit Kerberos erfordert die Einrichtung eines Benutzerkontos im Active Directory. Wichtig hierbei ist, dass folgende Option ausgewählt ist (vgl. Abb. 14):

- Kennwort läuft nie ab

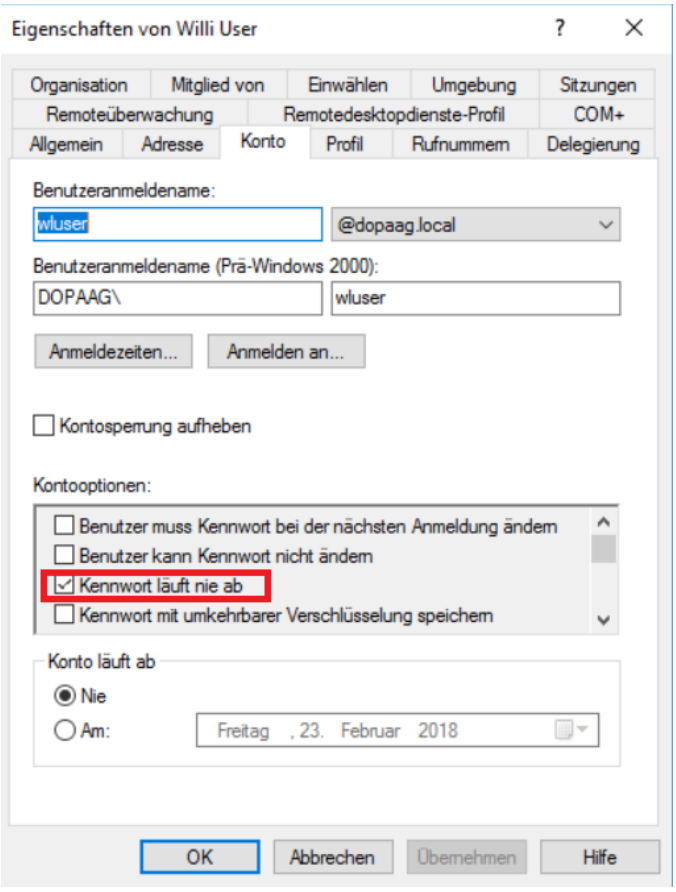

Abb. 15: Beispiel Benutzerkonto für Kerberos - Authentifizierung (Windows Server 2016)

Hinweis:

Falls in der Konfiguration für den Ldap –Import ein technischer Benutzer im AD angelegt wurde, kann dieser hier ebenfalls verwendet werden. Es ist darauf zu achten, die oben angezeigten Optionen beim Ldap – Benutzer ebenfalls zu verwenden. Dies vermeidet zusätzliche Benutzer im Active Directory. Für eine logische Trennung in der Konfiguration, empfiehlt es sich jedoch, einen eigenen Benutzer für die SPNs zu verwenden.

3.1.3 Einrichten der Service Principal Names (SPN)

Zusätzlich müssen für den angelegten Nutzer noch s.g. `Service Principal Names` angelegt werden. Diese müssen für den Rechner mit der Documents Installation angelegt werden. Hierfür steht der Befehl „`setspn`“ zur Verfügung. Dieser ist wie folgt zu verwenden und legt eine neue SPN für den HTTP Dienst auf `servername` für `username` an:

```
setspn –a HTTP/SERVERNAME username
```

```
Die Domäne "DC=dopaag,DC=local" wird überprüft.

Dienstprinzipalnamen (SPN) für CN=Willi User,CN=Users,DC=dopaag,DC=local werden registriert.
        HTTP/PAJOADDOPAAG
Aktualisiertes Objekt
```

Abb. 16: Einrichten der SPNs

Folgender Befehl zeigt alle dem User `wluser` zugewiesenen SPNs an:

```
setspn –l username
```

```
Registrierte Dienstprinzipalnamen (SPN) für CN=Willi User,CN=Users,DC=dopaag,DC=local:
        HTTP/PAJOADDOPAAG
```

Abb. 17: Alle dem User wluser zugewiesene SPNs anzeigen

Befehl zur Suche und Anzeige doppelt zugewiesener SPNs:

```
setspn –x
```

```
Die Domäne "DC=dopaag,DC=local" wird überprüft.
Eintrag 0 wird verarbeitet.
0 Gruppe von doppelten SPNs gefunden.
```

Abb. 18: doppelt zugewiesene SPNs anzeigen

Für die Nutzung mit **DOCUMENTS** müssen zwei SPNs für den **DOCUMENTS** -Tomcat eingerichtet werden. Der Service Name entspricht dem Domänennamen, auf den zugegriffen wird. Angenommen **DOCUMENTS** ist auf dem Rechner mit dem Namen „`portalserver`“ in der Domäne „`dopaag.local`“ installiert, sollten die Befehle für den

oben angelegten Benutzer wie folgt aussehen (bitte ausschließlich Großbuchstaben beim Servernamen inkl. Domänenname verwenden[8].):

```
setspn –a HTTP/PORTALSERVER wluser

setspn –a HTTP/PORTALSERVER.DOPAAG.LOCAL wluser
```

```
C:\Users\Administrator>setspn -a HTTP/PAJOSSOSERVER18 wluser
Die Domäne "DC=dopaag,DC=local" wird überprüft.

Dienstprinzipalnamen (SPN) für CN=Willi User,CN=Users,DC=dopaag,DC=local werden registriert.
        HTTP/PAJOSSOSERVER18
Aktualisiertes Objekt

C:\Users\Administrator>setspn -a HTTP/PAJOSSOSERVER18.DOPAAG.LOCAL wluser
Die Domäne "DC=dopaag,DC=local" wird überprüft.

Dienstprinzipalnamen (SPN) für CN=Willi User,CN=Users,DC=dopaag,DC=local werden registriert.
        HTTP/PAJOSSOSERVER18.DOPAAG.LOCAL
Aktualisiertes Objekt
```

Abb. 19: Befehl setspn -a in der Kommandozeile

WICHTIG: *Ein Service (HTTP/PORTALSERVER) darf immer nur genau einem User zugeordnet werden. Einem User können aber mehrere SPNs zugeordnet werden. Um sicherzustellen, dass diese Restriktionen eingehalten werden, kann der Befehl „setspn –x“ ausgeführt werden (siehe Erläuterung oben).*

[8] SPNs können von vielen verschiedenen Computersystemen verwendet werden. Nicht-Windows-basierte Betriebsysteme sind häufig case-sensitive und benötigen daher diese Schreibweise.

3.2 Konfigurationsdateien für SPNEGO

Für SPNEGO müssen zwei Konfigurationsdateien angelegt werden, die an einer beliebigen Stelle auf dem Installationsrechner von Documents (mit Tomcat) abgelegt werden können. Voraussetzung ist, dass an dieser Stelle für den jeweiligen Benutzer Lesezugriff besteht. Dies kann zum Beispiel der Pfad C:\Program Files\Documents<5/6>\SSO sein. Später wird der Pfad zu beiden Dateien in die Einstellungen des SpnegoHttpFilters in der Datei `web.xml` eingetragen (vgl. Kap.: 3.4.1). Die Datei befindet sich an der folgenden Stelle in einer Standardinstallation:

C:\Program Files\Documents<5/6>\tomcat<8/9>\webapps\documents\WEB-INF

Inhalt der Datei `login.conf`

```
spnego-client {
  com.sun.security.auth.module.Krb5LoginModule required;
};

spnego-server {
  com.sun.security.auth.module.Krb5LoginModule required
  storeKey=true
  isInitiator=false
  debug=true;
};
```

Inhalt der Datei `krb5.conf`

```
[libdefaults]
  default_realm = DOPAAG.LOCAL
  default_tkt_enctypes = aes256-cts-hmac-sha1-96
  default_tgs_enctypes = aes256-cts-hmac-sha1-96
  permitted_enctypes = aes256-cts-hmac-sha1-96

[realms]
DOPAAG.LOCAL  = {
    kdc = IP-Adresse oder DOPAAG.LOCAL
    default_domain = DOPAAG.LOCAL
}
[domain_realm]
  .DOPAAG.LOCAL = DOPAAG.LOCAL
```

Die Datei `login.conf` bleibt in der vorliegenden Form unverändert. In der Datei krb5.conf sind die Einstellungen im Abschnitt [libdefaults] im Hinblick auf eine Verschlüsselung mit AES256 erfolgt (vgl. Kap.: 3.1.1). Sollten Sie einen anderen Verschlüsselungsalgorithmus verwenden, sind hier andere Einträge erforderlich. Die seitens der Datei krb5.conf möglichen Einträge entnehmen Sie bitte der folgenden Webseite unter den Stichworten default_tkt_enctypes, default_tgs_enctypes und permitted_enctypes

https://web.mit.edu/kerberos/krb5-latest/doc/admin/conf_files/krb5_conf.html

Bitte beachten Sie, dass die ausgewählten Verschlüsselungsalgorithmen auch seitens des Betriebssystems unterstützt werden müssen.

Mit dem Befehlszeilenwerkzeug „klist“ kann auf dem Client-Rechner in der Domäne der eingestellte Verschlüsselungstyp angezeigt werden (vgl. Kap.: 3.6.4). In der Datei `krb5.conf` muss der Domänenname “`DOPAAG.LOCAL`” durch den korrekten Domänennamen ersetzt werden. Es ist zwingend darauf zu achten, dass für den Domänennamen Großschreibweise genutzt wird. Sollten Subdomänen eingesetzt werden, würde das Schema entsprechend „`SUBDOMAIN.DOPAAG.LOCAL`“ lauten.

Beim Key Distribution Center (kdc) muss die IP – Adresse des AD – Rechners oder der Domänenname (wie oben beschrieben) angegeben werden. Hier werden Domänencontroller automatisch ausgewählt, falls korrekt konfiguriert. Dies könnte beispielsweise mit Hilfe des Tools *HelloKDC.java* überprüft werden (vgl. Kap.:3.6.3)

```
<init-param>
    <param-name>spnego.krb5.conf</param-name>
    <param-value>C:\Program Files\Documents5\sso\krb5.conf</param-value>
</init-param>
<init-param>
    <param-name>spnego.login.conf</param-name>
    <param-value>C:\Program Files\Documents5\sso\login.conf</param-value>
</init-param>
```

Abb. 20: Eintrag des Speicherpfads der Konfigurationsdateien in der web.xml

3.3 Installation von SPNEGO

Zunächst muss das aktuelle SPNEGO Paket von

http://spnego.sourceforge.net/

unter → **Links** → **Download** heruntergeladen werden. Die heruntergeladene `.jar` – Datei muss in das Verzeichnis **C:\Program Files\Documents<5/6>\tomcat<8/9>\webapps\documents\WEB-INF\lib**

kopiert werden. Danach ist ein Neustart des Tomcat erforderlich. SPNEGO wurde in der Version r9 erfolgreich getestet.

3.4 Einträge in der web.xml

Zur Anmeldung mittels Autologin orientieren Sie sich bitte an der folgenden URL, da sie zu der unten stehenden Konfiguration passt („dopaag“ ist im vorliegenden Beispiel der Mandantenname):

http://servername:8080/documents/autologin/login?pri=dopaag

Das folgende Beispiel stellt einen Quick-View-Link auf ein EEX – Archiv dar:

http://servername:8080/documents/jsp/qv?pri=9999&vw=Media&q_Beschreibung=Thema

„*9999*“ ist der Mandantenname, „*Media*“ der Name einer View und „*Beschreibung*“ der Name eines Feldes der Archivmappe.

Für die Einrichtung der *Kerberos*-Authentifizierung muss außerdem der SPNEGO Filter in die Datei

C:\Program Files\Documents<5/6>\tomcat<8/9>\webapps\documents\WEB-INF\web.xml

hinzugefügt werden. Dazu muss folgender Text nach dem Conversation Filter, SessionSetupFilter und LoginFilter eingetragen werden. Bitte beachten Sie, dass der spnegoHttpFilter vor dem SSOFilter stehen muss. Im SPNEGO – Filter sind die absoluten Pfade zu den Konfigurationsdateien einzutragen. Außerdem sind Benutzerkonto und Kennwort einzugeben. Aus Sicherheitsgründen sind im vorliegenden Beispiel die Parameter mit dem Namensanteil „allow“ deaktiviert. Die Parameterwerte spnego-client und spnego-server müssen mit den entsprechenden Bezeichnern in der Datei `login.conf` (vgl. Kap. 3.2) übereinstimmen. Eine nähere Erläuterung der einzelnen Parameter entnehmen Sie bitte der folgenden Internetseite:

http://spnego.sourceforge.net/reference_docs.html

Ab Documents 5.0 d werden diese Einträge in der web.xml mit ausgeliefert. Sie müssen lediglich einkommentiert werden. Dabei können noch individuelle Anpassungen, je nach vorliegender Konfiguration erforderlich sein (Bsp.: Anpassung des Pfades zur Konfigurationsdatei).

3.4.1 Einträge im SPNEGO-Filter

```
<!— Dieser Filter ist in der Standard web.xml schon vorhanden (auskommentiert) -->
<filter>
  <filter-name>spnegoHttpFilter</filter-name>
                <filter-class>net.sourceforge.spnego.SpnegoHttpFilter</filter-class>
                <init-param>
                        <param-name>spnego.allow.basic</param-name>
                        <param-value>false</param-value>
                </init-param>
                <init-param>
                        <param-name>spnego.allow.localhost</param-name>
                        <param-value>false</param-value>
                </init-param>
                <init-param>
                        <param-name>spnego.allow.unsecure.basic</param-name>
                        <param-value>false</param-value>
                </init-param>
```

```
            <init-param>
                <param-name>spnego.login.client.module</param-name>
                <param-value>spnego-client</param-value>
            </init-param>
            <init-param>
                <param-name>spnego.krb5.conf</param-name>
                <param-value>abs.Pfad\Name der Konfigurationsdatei krb5.conf</param-value>
            </init-param>
            <init-param>
                <param-name>spnego.login.conf</param-name>
                <param-value> abs.Pfad\Name der Konfigurationsdatei login.conf</param-value>
            </init-param>
            <init-param>
                <param-name>spnego.preauth.username</param-name>
                <param-value>Name des Benutzerkontos aus Kapitel 3.1.2</param-value>
            </init-param>
            <init-param>
                <param-name>spnego.preauth.password</param-name>
                <param-value>Kennwort zu obigem Benutzerkonto</param-value>
            </init-param>
            <init-param>
                <param-name>spnego.login.server.module</param-name>
                <param-value>spnego-server</param-value>
            </init-param>
            <init-param>
                <param-name>spnego.prompt.ntlm</param-name>
                <param-value>false</param-value>
            </init-param>
            <init-param>
                <param-name>spnego.logger.level</param-name>
                <param-value>1</param-value>
            </init-param>
        </filter>
        <filter-mapping>
            <filter-name>SpnegoHttpFilter</filter-name>
            <url-pattern>/autologin/login</url-pattern>
            <url-pattern>/jsp/qv</url-pattern>
        </filter-mapping>
```

3.4.2 Einträge im SSO-Filter (Documents 5)

```
        <!— Dieser Filter ist in der Standard web.xml schon vorhanden (auskommentiert) -->
  <filter>
            <filter-name>SSOFilter</filter-name>
            <filter-class>de.otris.documents.web.filter.SSOFilter</filter-class>
</filter>
<filter-mapping>
            <filter-name>SSOFilter</filter-name>
```

```
                <url-pattern>/autologin/login</url-pattern>
                <url-pattern>/jsp/qv</url-pattern>
</filter-mapping>
```

3.4.3 Einträge im SSO Filter (Documents 6)

Der folgende SSOFilter ist ab Documents 6 standardmäßig schon aktiv. Im Fall dass der *PropertyMode* den Wert *„true“* hat und somit aktiv ist, funktioniert SSO nur wenn die globale Eigenschaft (Property) *ssoLoginMethod = sso* gesetzt ist Wenn diese Eigenschaft nicht gesetzt ist, würde SSO nicht funktionieren. Bei nicht gesetzter Eigenschaft *ssoLoginMethod*, würde SSO nur funktionieren, wenn der *PropertyMode* aus ist und somit den Wert *„false“* hat.

```
<!— Dieser Filter ist in der Standard web.xml schon vorhanden (einkommentiert und aktiv) -->
        <filter>
                <filter-name>SSOFilter</filter-name>
                <filter-class>de.otris.documents.web.filter.SSOFilter</filter-class>
                <init-param>
                        <param-name>PropertyMode</param-name>
                        <param-value>true</param-value>
                </init-param>
        </filter>

        <filter-mapping>
                <filter-name>SSOFilter</filter-name>
                <url-pattern>/autologin/login</url-pattern>
                <url-pattern>/jsp/qv</url-pattern>
        </filter-mapping>
```

3.4.4 Modifizierungen bei allen anderen Filtern

Bitte beachten Sie, dass **bei allen anderen Filtern** das url-pattern für den Autologin (markierter Bereich) wie folgt aussehen muss (Bsp.: hier: Session Setup Filter): Ab Documents 5.0 c HF 1 werden diese Einträge in der web.xml mit ausgeliefert. Es muss also seitens der Benutzer keine Änderung mehr vorgenommen werden.

```
<filter-name>SessionSetupFilter</filter-name>
<url-pattern>*.act</url-pattern>
<url-pattern>*.jsp</url-pattern>
<url-pattern>/autologin/login</url-pattern>
```

Abb. 21: Modifikationen bei allen Filtern

3.5 Einrichtung von Firefox

Um *Kerberos* mit *Firefox* nutzen zu können, muss eine Einstellung im Browser vorgenommen werden. Hierzu wird die Konfiguration aufgerufen, indem in der Adresszeile des *Firefox* „`about:config`“ angegeben wird (vgl. Abb. 19).

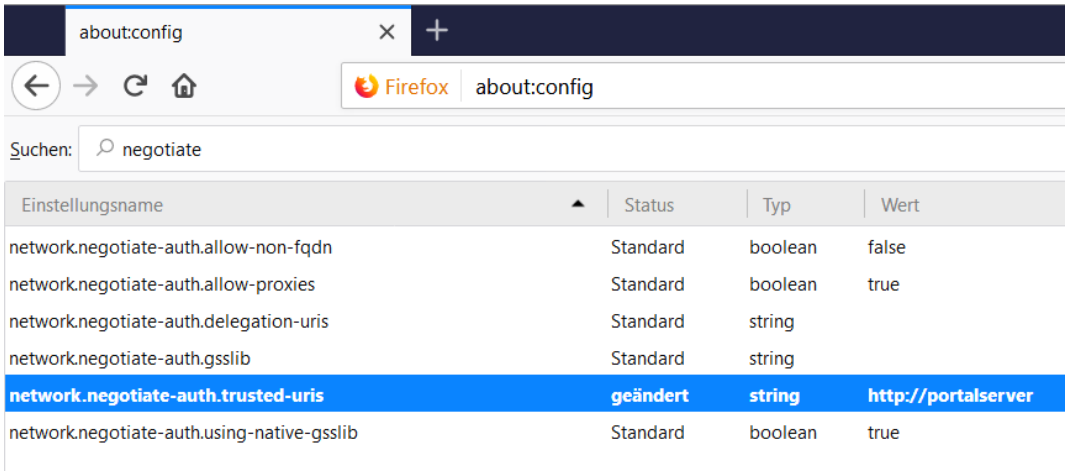

Abb. 22: Firefox-Einstellungen

Hier muss die URL des Anwendungsserver-Schlüssels „`network.negotiate-auth.trusted-uris`“ eingetragen werden.

3.6 Troubleshooting SPNEGO mit Kerberos

Da die *Kerberos*-SSO-Einrichtung recht komplex ist, gibt es viel Potential für eine Fehlkonfiguration, die in der Regel in einer recht unverständlichen Fehlermeldung endet. Diese Zusammenstellung zeigt Fehlkonfigurationen und dient als Hilfestellung bei der Analyse.

3.6.1 Häufige Fehlerquellen:

- AD ServiceUser ist gemäß Anleitung angelegt worden.
- Überprüfen Sie die Kennwörter in den Konfigurationsdateien!
- Die *Kerberos*-Ausgaben im *Tomcat* lassen nicht auf ein korrektes Kennwort schließen. Bitte manuell überprüfen.
- Benutzeranmeldung erfolgt in der Domäne, für welche die Konfiguration erstellt wurde.
- In der Datei `krb5.conf` kann die Groß- und Kleinschreibung bei der Domäne relevant sein.
- Die Uhren von Client und Server dürfen nicht mehr als 5 min voneinander abweichen.
- Die Größe des Kerberos Tokens wächst an, wenn der Benutzer in vielen AD-Gruppen Mitglied ist. In diesem Fall muss die maxHttpHeaderSize in der Datei

`server.xml` erhöht werden. Sie steht standardmäßig auf 8.192 (8 KB) falls Sie nicht definiert ist. Wenn die hier eingetragene Größe zu klein ist, kann es zu http 400 – Fehlern beim Aufruf der Autologin-Url kommen. Die Datei liegt im folgenden Verzeichnis in einer Standardinstallation: C:\Program Files\Documents<5/6>\tomcat<8/9>\conf.

```
<Connector port="8080" protocol="HTTP/1.1"
           connectionTimeout="20000"
           redirectPort="8443"
           URIEncoding="UTF-8"
           maxHttpHeaderSize="16384"
           />
```

Abb. 23: Erhöhung der maxHttpHeaderSize in der server.xml

- Die SPNs müssen korrekt für den im ersten Punkt erwähnten AD Service User gesetzt werden.
    - Bewährt haben sich folgenden SPNs:
      Zwingend http/<servername> und http/<servername>.<domäne>
      Optional http/<aliasname> und http/<aliasname>.<domäne>
- Die Einträge in der web.xml müssen in der richtigen Reihenfolge und an der richtigen Stelle sein.
    - An den Waffle-Einträgen orientieren.
- Sollten alle o.g. Punkte nicht zum Erfolg führen, so ist der Preflight Check auf der SPNEGO-Seite nochmal durchzuarbeiten:
    - **http://spnego.sourceforge.net/pre_flight.html**
    - Wenn auch das nicht hilft, kann das Programm *HelloKDC.java* auf dem Server übersetzt und ausgeführt werden. Parameter anpassen nicht vergessen! Die Fehlermeldungen sind hier im Gegensatz zum Servletfilter sehr sprechend! **http://spnego.sourceforge.net/troubleshoot_hello_kdc.html** (siehe Kapitel 3.6.3)
- Generell kann ein Neustart des Rechners mit der Documents – Serverinstallation nach Änderung der Konfiguration sinnvoll sein. So wird die Verbindung zum Active Directory bzw. zum Key Distribution Center (KDC) neu aufgebaut. Außerdem werden Netzwerkverbindungen neu aufgebaut, Caches gelöscht und Umgebungsvariablen neu ausgelesen.

3.6.2 Fehlermeldungen und Maßnahmen

„Checksum failed“ (Meldung im Tomcat, nicht im HelloKDC!!!)

→ Die Fehlermeldung ist zu unspezifisch um unmittelbar eine Schlussfolgerung zu ziehen

Hier bitte unbedingt zur Feinanalyse das Programm „HelloKDC“ ausführen. (vgl. Kapitel 3.6.3)

„Cannot find key of appropriate type to decrypt…“(Meldung im Tomcat)

→ Die Einstellungen in den Eigenschaften für Netzwerksicherheit (vgl. Kapitel 3.1.1) passen nicht zu den Einstellungen in der Datei krb5.conf. Bitte gleichen Sie diese an.

„NTLM specified. Downgraded to Basic Auth (and/or SSL) but downgrade not supported.“ (Meldung im Tomcat)

→ Die Einstellungen in den Eigenschaften für Netzwerksicherheit (vgl. Kapitel 3.1.1) passen nicht zu den Einstellungen in der Datei krb5.conf. Bitte gleichen Sie diese an.

„KrbException: Encryption type RC4 with HMAC is not supported/enabled“ (Fehlermeldung im Tomcat)

→ Die Einstellungen in den Eigenschaften für Netzwerksicherheit (vgl. Kapitel 3.1.1) passen nicht zu den Einstellungen in der Datei krb5.conf. Bitte gleichen Sie diese an.

„doSpnegoAuth context not established“

→ Hier wird die Autologin – URL auf einem Serverbetriebssystem statt auf einem Clientbetriebsystem wie Windows 10 abgesetzt (vgl. Kap.:1.2.3)

3.6.3 HelloKDC – Config-Test

Das Java Tool *HelloKDC* kann zum Testen der beiden config – files krb5.conf und login.conf verwendet werden. Nähere Infos erhalten Sie an der folgenden Stelle:
http://spnego.sourceforge.net/troubleshoot_hello_kdc.html

Anpassungen müssen an den folgenden Stellen in der Datei HelloKDC.java gemacht werden. Die Zugangsdaten des Benutzers sowie die Namen der Konfigurationsdateien müssen hier angegeben werden. Dabei müssen die Konfigurationsdateien im gleichen Verzeichnis wie die Programmdatei `HelloKDC.java` liegen.

```
// Domain (pre-authentication) account

final String username = "Name des Benutzerkontos aus Kapitel 3.1.1";

// Password for the pre-auth acct.

final String password = "Kennwort des obigen Benutzerkontos";
```

```
// Name of our krb5 config file

final String krbfile = "krb5.conf";

// Name of our login config file

final String loginfile = "login.conf";
```

Abb. 24: Ausschnitt aus dem Skript HelloKDC.java

Anschließend muss das *HelloKDC.java File* mit dem *javac compiler* in einer Kommandozeile kompiliert werden. Dies erfolgt über folgende Kommandozeile:

```
C:\Program Files\Documents5\sso>javac HelloKDC.java
```

Abb. 25: Kompilierung von HelloKDC.java

Bei der erfolgreichen Ausführung erscheint die folgende Ausgabe:

```
Connection Test successful.
```

Folgende Fehlermeldungen kommen häufig vor:

- Checksum failed
- Client not found in Kerberos database (6)
- KDC has no support for encryption type (14)
- Clients credentials have been revoked (18)
- Pre-authentication information was invalid (24)
- Cannot get kdc for realm
- The module name spnego-client was not found in the login file
- javax.security.auth.login.LoginException: null (68)
- Stream modified (41)
- Checksum failed
    - Überprüfen Sie die Eingaben von Benutzernamen und Passwort auf richtige Schreibweise!
- Client not found in Kerberos database (6)
    - Überprüfen Sie die Schreibweise des Usernames und stellen Sie das Vorhandensein des Benutzers im AD sicher.
- KDC has no support for encryption type (14)
    - Überprüfen Sie bitte die `krb5.conf`- Datei auf korrekt gewählte Verschlüsselungstypen!
- Clients credentials have been revoked (18)

    - Überprüfen Sie, ob der Benutzer-Account im AD gesperrt, ausgelaufen oder deaktiviert ist!

- Pre-authentication information was invalid (24)
    - Überprüfen Sie die Eingaben von Benutzernamen und Passwort auf richtige Schreibweise!

- Cannot get kdc for realm
    - Überprüfen Sie die Einträge `[libdefaults]` und `[realms]` in der Datei `krb5.conf` auf Rechtschreibfehler. Groß- und Kleinschreibung beachten!

- The module name spnego-client was not found in the login file
    - Überprüfen Sie die Datei `login.conf` auf Rechtschreibfehler!
    - In Einzelfällen kann es notwendig sein, die Datei zu löschen und neu zu erstellen. Dann muss der Inhalt neu hineinkopiert werden. Dies kann hilfreich sein in Fällen, in denen die Kodierung einer Datei falsch ist oder wenn sich in der Datei Steuerzeichen befinden, die das Auslesen der Konfiguration stören.

- javax.security.auth.login.LoginException: null (68)
    - Überprüfen Sie die Einträge `[libdefaults]` und `[realms]` in der Datei `krb5.conf` auf Rechtschreibfehler. Groß- und Kleinschreibung beachten!

- Stream modified (41)
    - Stellen Sie sicher, dass der Eintrag „DOMAIN.LOCAL“ in der Datei `krb5.conf` ausschließlich großgeschrieben ist.

3.6.4 Hilfsmittel Befehlszeilenwerkzeug „*klist*“

Um die korrekte Konfiguration von *Kerberos* zu überprüfen, ist es hilfreich zu wissen, welche Tickets einem Client-System zugewiesen sind. Dies kann mit dem Befehlszeilenwerkzeug „*klist*“ auf dem Client-Rechner in der Domäne durchgeführt werden, das ab Windows Server 2008 ausgeliefert wird. Das Tool ermöglicht, Kerberos-Tickets, die für die aktuelle Sitzung ausgestellt wurden, zu überwachen und zu löschen. Man kann sich die *Ticket Granting Tickets (TGTs)* anzeigen lassen. Es wird vor allem für das Troubleshooting benötigt, um nachprüfen zu können, ob die Tickets korrekt ausgestellt wurden. Hier kann u.a. der eingestellte Verschlüsselungstyp eingesehen werden (vgl. Kap.: 3.2).

```
Syntax: klist.exe [Befehl]

Befehlsliste:
  [tickets] [-lh <LogonId.HighPart>] [-li <LogonId.LowPart>]
  tgt [-lh <LogonId.HighPart>] [-li <LogonId.LowPart>]
  purge [-lh <LogonId.HighPart>] [-li <LogonId.LowPart>]
  sessions [-lh <LogonId.HighPart>] [-li <LogonId.LowPart>]
  kcd_cache [-lh <LogonId.HighPart>] [-li <LogonId.LowPart>]
  get <SPN> [-lh <LogonId.HighPart>] [-li <LogonId.LowPart>]
            [-kdcoptions <options>] [-cacheoptions <options>]
  add_bind <DOMAIN> <DC>
  query_bind
  purge_bind
```

Abb. 26: Überblick zur Syntax des Befehls klist

```
C:\Program Files\Documents5\sso>klist -li wluser

Aktuelle Anmelde-ID ist 0:0x120edb

Zwischengespeicherte Tickets: (2)

#0>     Client: Administrator @ DOPAAG.LOCAL
        Server: krbtgt/DOPAAG.LOCAL @ DOPAAG.LOCAL
        KerbTicket (Verschlüsselungstyp): AES-256-CTS-HMAC-SHA1-96
        Ticketkennzeichen 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
        Startzeit: 11/27/2017 8:29:49 (lokal)
        Endzeit:   11/27/2017 18:29:49 (lokal)
        Erneuerungszeit: 12/4/2017 8:29:49 (lokal)
        Sitzungsschlüsseltyp: AES-256-CTS-HMAC-SHA1-96
        Cachekennzeichen: 0x1 -> PRIMARY
        KDC aufgerufen: pajoaddopaag.dopaag.local

#1>     Client: Administrator @ DOPAAG.LOCAL
        Server: LDAP/pajoaddopaag.dopaag.local/dopaag.local @ DOPAAG.LOCAL
        KerbTicket (Verschlüsselungstyp): AES-256-CTS-HMAC-SHA1-96
        Ticketkennzeichen 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
        Startzeit: 11/27/2017 8:29:49 (lokal)
        Endzeit:   11/27/2017 18:29:49 (lokal)
        Erneuerungszeit: 12/4/2017 8:29:49 (lokal)
        Sitzungsschlüsseltyp: AES-256-CTS-HMAC-SHA1-96
        Cachekennzeichen: 0
        KDC aufgerufen: pajoaddopaag.dopaag.local
```

Abb. 27: Auflistung der Kerberos – Tickets für den Benutzer wluser

Es kann bisweilen vorkommen, dass man Kerberos Tickets aus dem Cache löschen muss. Auf diese Weise kann man das erneute Anfordern neuer Tickets erzwingen, um zum Beispiel neue Berechtigungen ohne Neustart zu testen. Auch kann sich eine Konfiguration geändert haben. In diesem Fall kann es passieren, dass ein altes Ticket wiederverwendet wird, anstatt ein neues mit der korrekten Konfiguration zu erzeugen. Dies würde in der Folge zu Fehlern führen.
Um Kerberos-Tickets aus dem Cache zu löschen muss der Befehl „klist purge“ ausgeführt werden. Daraufhin lassen sich keine Kerberos – Tickets mehr aufrufen.

```
C:\Users\AdministratorOld>klist purge

Aktuelle Anmelde-ID ist 0:0x14f066
        Alle Tickets werden gelöscht:
        Ticket(s) gelöscht.

C:\Users\AdministratorOld>klist -li wluser

Aktuelle Anmelde-ID ist 0:0x14f066

Zwischengespeicherte Tickets: (0)

C:\Users\AdministratorOld>klist tickets

Aktuelle Anmelde-ID ist 0:0x14f066

Zwischengespeicherte Tickets: (0)
```

Abb. 28: Kerberos – Tickets mit „klist purge“ bereinigen.

4. Häufige Fehler

Genereller Hinweis zum Testen von SSO:

Für jeden neuen Versuch der automatischen Anmeldung per SSO müssen ALLE laufenden Browser-Fenster und Prozesse beendet sein. Nur so kann sichergestellt werden, dass ein neuer Versuch der automatischen Anmeldung unternommen wird.

Nach der Einrichtung von SSO startet der Tomcat nicht mehr bzw. stürzt während des Starts ab.

Die Ursache hierfür sind meistens Fehler in der Datei `web.xml`. Auf Folgendes ist besonders zu achten:

- Die Datei muss **valides XML** enthalten, d.h. vor allem, dass jedes geöffnete Element auch wieder geschlossen wird. (Vorsicht vor „copy & paste“-Fehlern).
- Bei der Einrichtung der Filter und generell beim Bearbeiten der *web.xml* ist es wichtig, auf **Groß- und Kleinschreibung** zu achten, da dies besonders bei der Angabe von Java-Klassennamen wichtig ist.
- Zur Sicherheit sollten außerdem **Leerzeichen und Zeilenumbrüche** innerhalb einzelner XML-Elemente, die Konfigurationsinformationen enthalten, vermieden werden.
- Hierzu können Sie auch einen Blick in die Log-Dateien mit dem Namensanteil „catalina“ werfen. Sie finden diese an der folgenden Stelle in einer Standardinstallation:
  C:\Program Files\Documents<5/6>\logs\tomcat

Beim Versuch der automatischen Anmeldung wird ein Windows Login-Fenster angezeigt.

Hierfür gibt es verschiedene Ursachen, die teilweise auch in mehrfacher Kombination auftreten. Deshalb sollten folgende Punkte beachtet werden:

- Unabhängig von der verwendeten Authentifizierungsmethode müssen **immer zwei Filter** in der *web.xml* eingerichtet werden.
  - 1.) Der Filter für die Authentifizierung (Waffle, SPNEGO)
  - 2.) Der SSOFilter
- Es ist absolut wichtig, dass die „filter-mapping“-Elemente für den SSOFilter in der *web.xml* **immer NACH** den „filter-mapping“- Elementen für die Authentifizierungsmethode eingetragen werden.

- Der Internet Explorer muss so eingestellt sein, dass er **die Login Informationen automatisch sendet**. Der einfachste Weg dies zu erreichen ist in den meisten Fällen, den Server auf dem die Documents Seiten liegen, in die **Intranet-Zone oder zu den Trusted-Sites** hinzuzufügen.
- **Mozilla Firefox** muss speziell konfiguriert werden (vgl. Kapitel 2.4 und 3.6)

Test, ob SSO – Rechnerumgebung überhaupt für SSO geeignet ist

a.) Waffle – Einrichtung gemäß Kapitel 2 ausführen:
    a. Wenn Waffle funktioniert, dann ist es ein SPNEGO - spezifisches Problem.
    b. Wenn Waffle nicht funktioniert, liegt es an der Testumgebung.

b.) Kleinere Tests an der Umgebung: Ist der AD – Rechner erreichbar? / Sind alle Maschinen in der Domäne?
    a. Kann der AD – Rechner vom Server- und Clientrechner angepingt werden?
    b. Funktioniert die Verbindung mittels des Befehls: „telnet Servername Port“
    c. Folgender Konsolenbefehl stellt fest, in welcher Domäne der Rechner ist, auf dem der Befehl ausgeführt wird:
        i. Deutsches Betriebssystem: systeminfo | findstr /i "Domäne"
        ii. Englisches Betriebssystem: systeminfo | findstr /i "domain"

5. Abbildungsverzeichnis

Abb. 1: Standard-Anmeldedialog unter Windows 10 an der Domäne „dopaag“ mit dem Benutzer „schreiber“ 7
Abb. 2: Automatisches Login 8
Abb. 3: Dialog "Eigenschaften von Internet" 9
Abb. 4: Automatisches Anmelden nur in der Intranetzone aktiviert 10
Abb. 5: Integrierte Windows-Authentifizierung aktivieren 11
Abb. 6: Aufnahme des Servernamens in die Liste „Lokales Intranet“ 12
Abb. 7: Systemumgebung für die Nutzung von SSO 13
Abb. 8: Standardlink für die automatische Anmeldung bei hasAutologinLink = true 14
Abb. 9: Modifikationen bei allen Filtern 18
Abb. 10: Logdatei mit dem Namensanteil „stdout“ 19
Abb. 11: Beispiel für den Aufbau der Datei „logback.xml“ 19
Abb. 12: für Kerberos zulässige Verschlüsselungstypen konfigurieren (Windows Server 2016) 21
Abb. 13: Auswahl der zulässigen Verschlüsselungsverfahren (Windows Server 2016) 21
Abb. 14: Einstellungen am SPN „wluser“ im Active Directory Verwaltungscenter (Windows Server 2016) 22
Abb. 15: Beispiel Benutzerkonto für Kerberos - Authentifizierung (Windows Server 2016) 22
Abb. 16: Einrichten der SPNs 23
Abb. 17: Alle dem User wluser zugewiesene SPNs anzeigen 23
Abb. 18: doppelt zugewiesene SPNs anzeigen 23
Abb. 19: Befehl setspn -a in der Kommandozeile 24
Abb. 20: Eintrag des Speicherpfads der Konfigurationsdateien in der web.xml 26
Abb. 21: Modifikationen bei allen Filtern 29
Abb. 22: Firefox-Einstellungen 30
Abb. 23: Erhöhung der maxHttpHeaderSize in der server.xml 31
Abb. 24: Ausschnitt aus dem Skript HelloKDC.java 33
Abb. 25: Kompilierung von HelloKDC.java 33
Abb. 26: Überblick zur Syntax des Befehls klist 35
Abb. 27: Auflistung der Kerberos – Tickets für den Benutzer wluser 35
Abb. 28: Kerberos – Tickets mit „klist purge“ bereinigen. 36